Cetus rfq

Audit Report





contact@bitslab.xyz



https://twitter.com/movebit_

Tue Jun 24 2025

Cetus rfq Audit Report

1 Executive Summary

1.1 Project Information

Description	This is a decentralized market maker contract.
Type	Dex
Auditors	MoveBit
Timeline	Tue Jun 17 2025 - Fri Jun 20 2025
Languages	Move
Platform	Sui
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/CetusProtocol/rfq
Commits	6a932e56b3002310aec96ecd11704ccb4a6851ab ae5f9d6524823c7013933bb33ebc6eb6377e9ba0 470430c51c5f1d7dc37762ccd492998fa8eb5a87

1.2 Files in Scope

The following are the SHA1 hashes of the original reviewed files.

ID	File	SHA-1 Hash
MOV	packages/validator/Move.toml	9685dcc6e601e9b9c747e0601c5b45f19582c834
ACA	packages/validator/sources/admin_cap.move	254e5ccbe982accced16ffc57a7e2b4fe56c4cc3
ERR	packages/validator/sources/errors.move	7835f884e171dccba5f4593c9ee991bdfdb76f96
VER	packages/validator/sources/versioned.move	2d4e6765b58d8849482ce81ca043561f7aa60bff
FTI	packages/validator/sources/fee_tier.move	df980d5584bdd762aa28616eb6c336b1ddf1ba43
CON	packages/validator/sources/confirmer.move	d865d40f60e0d936c305896d8c6056156346f62c
MOV1	packages/mm_demo/Move.toml	6572b25f7599a3b5bc71df2217cd5494973b6a5f
MDE	packages/mm_demo/sources/mm_demo.move	ff5a30f3fa4e624e44cd4ff47630b7948f1f40bf

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	7	6	1
Informational	1	1	0
Minor	3	2	1
Medium	1	1	0
Major	2	2	0
Critical	0	0	0

1.4 MoveBit Audit Breakdown

MoveBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow by bit operations
- Number of rounding errors
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting
- Unchecked CALL Return Values
- The flow of capability
- Witness Type

1.5 Methodology

The security team adopted the **"Testing and Automated Analysis"**, **"Code Review"** and **"Formal Verification"** strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency / failure rollback / unit testing / value overflows / parameter verification / unhandled errors / boundary checking / coding specifications.

(2) Code Review

The code scope is illustrated in section 1.2.

(3) Formal Verification(Optional)

Perform formal verification for key functions with the Move Prover.

(4) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by `Cetus` to identify any potential issues and vulnerabilities in the source code of the `rfq` smart contract, as well as any contract dependencies that were not part of an officially recognized library. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.

During the audit, we identified 7 issues of varying severity, listed below.

ID	Title	Severity	Status
CON-1	Typo	Informational	Fixed
FTI-1	Lack of Function to Withdraw the Fee	Major	Fixed
FTI-2	Redundant Abilities of Event Object	Minor	Fixed
MDE-1	Signature Replay	Major	Fixed
MDE-2	Public Functions Lack Of Version Control	Medium	Fixed
MDE-3	Missing Check for Signature	Minor	Fixed
MDE-4	Potential Front Run in `swap()`	Minor	Acknowledged

3 Participant Process

Here are the relevant actors with their respective abilities within the Cetus rfq Smart Contract :

Admin

- Admin can set the default fee rate through the `set_default_fee_rate()` function.
- Admin can set custom fee rates for specific coin pairs through the `set_fee_rate()` function.
- Admin can upgrade contract version through the `upgrade()` function.
- Admin can withdraw tokens from their Vault through the `withdraw()` function.

User

- User can deposit tokens into any Vault through the `deposit()` function.
- User can create swap certificates through the `new_swap_cert()` function.
- User can execute token swaps with valid signature through the `swap()` function.
- User can call the `receive_fee()` function to add a token to `FeeTier`.

4 Findings

CON-1 Typo

Severity: Informational

Status: Fixed

Code Location:

packages/validator/sources/confirmer.move#67

Descriptions:

The name of the function `destory_swap_cert()` probably be changed to `destroy_swap_cert`.

Suggestion:

It is recommended to update to `destroy_swap_cert`.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

FTI-1 Lack of Function to Withdraw the Fee

Severity: Major

Status: Fixed

Code Location:

packages/validator/sources/fee_tier.move

Descriptions:

In the `fee_tier` module, the `receive_fee()` is used to receive the fee during the swap, but there's no function to withdraw the fee.

Suggestion:

It is recommended to add a function to withdraw the fee.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

FTI-2 Redundant Abilities of Event Object

Severity: Minor

Status: Fixed

Code Location:

packages/validator/sources/fee_tier.move#21,26;

packages/validator/sources/confirmer.move#21

Descriptions:

Only `copy` and `drop` abilities are needed for event objects, so the `store` ability is redundant.

Suggestion:

It is recommended to modify the abilities of events.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

MDE-1 Signature Replay

Severity: Major

Status: Fixed

Code Location:

packages/mm_demo/sources/mm_demo.move#91-135

Descriptions:

The data verified by `verify_internal()` does not contain `quote_id` in `SwapCert`. Before the deadline, the attacker does not need to request a signature again before performing an interactive operation. The `SwapCert` is constructed with the same parameters as the previously signed data and the previously used signature can be used to perform the swap operation.

Suggestion:

It is recommended to verify the data of `quote_id` in `SwapCert` in the `verify_internal()` function to ensure the uniqueness of `SwapCert` and record whether it has been used.

Resolution:

This issue has been fixed for now. Please be aware that generating multiple vaults using the same address will lead to signature replay.

MDE-2 Public Functions Lack Of Version Control

Severity: Medium

Status: Fixed

Code Location:

packages/mm_demo/sources/mm_demo.move#59,72

Descriptions:

Some functions lack version control, such as `deposit()` and `withdraw()`.

If those are missing, users might call the deprecated functions.

Suggestion:

It is suggested to add the version control logic in those modules.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

MDE-3 Missing Check for Signature

Severity: Minor

Status: Fixed

Code Location:

packages/mm_demo/sources/mm_demo.move#108,138,149

Descriptions:

The contract does not verify the format and length of the signature. If a malformed signature is allowed to be passed in, it may cause hexadecimal decoding failure and overflow error in the subsequent subtraction operation `length - 32 - 1`.

Suggestion:

It is recommended to verify the format and length of the signature.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

MDE-4 Potential Front Run in `swap()`

Severity: Minor

Status: Acknowledged

Code Location:

packages/mm_demo/sources/mm_demo.move#91

Descriptions:

The `swap()` function is used to swap tokens with the owner's signature, but the signature doesn't contain the signer address, which makes it possible to front-run the swap.

Suggestion:

It is recommended to include the signer address in the signature to avoid this issue.

Resolution:

Project party explanation:

1. The signature in the contract does not contain the user's address. This is intentional. The contract will not know the user's address that initiated the transaction before the transaction is completed to prevent manipulation.
2. The contract's quotation interface only allows the quotation service to call, and the transaction is constructed by the quotation service. The possibility of preemption is extremely low. Even if preemption occurs, the result for the user is that the transaction fails, and the result for the contract is consistent. No asset loss will occur.

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't post any direct risk. Developers are encouraged to fix them.
- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Partially Fixed:** The issue has been partially resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.

